숨은길(sumeungil.co.kr) 보안 점검 — 5차 세션: SAST + 의존성 취약점

점검일: 2026-08-10 방식: 사용자 제공 저장소(`git@github.com:qweasd-22/sumeungil.git`)를 로컬 clone 후 소스코드 정적 분석 + 의존성 버전 대조 이 문서는: 1~4차 블랙박스 점검에 이은 화이트박스(소스코드) 점검 결과입니다.

🔴🔴 최우선 — Starlette "BadHost" 취약점 (CVE-2026-48710)

이번 감사 전체를 통틀어 가장 시급한 단일 항목입니다. 블랙박스 점검으로는 절대 발견할 수 없었던 문제이며, 소스코드/의존성 접근이 있었기에 특정 가능했습니다.

무엇인가요?

`backend/requirements.txt`에는 `fastapi==0.115.6`만 고정돼 있고, FastAPI가 내부적으로 사용하는 **Starlette**라는 프레임워크의 버전은 별도로 고정돼 있지 않습니다(lock 파일이 없음). FastAPI 0.115.6이 자동으로 끌어오는 Starlette 버전대는, 2026년 5월 26일 공개된 심각한 취약점의 영향 범위(**0.8.3 ~ 1.0.0**, 수정판은 **1.0.1**)에 들어갈 가능성이 매우 높습니다.

왜 위험한가요?

이 취약점("BadHost")은 웹 요청의 `Host` 헤더에 이상한 문자를 하나만 섞어 보내면, 서버 프레임워크가 요청 경로를 잘못 해석해서 경로 기반 인증/권한 검사를 우회할 수 있게 만듭니다. FastAPI뿐 아니라 LiteLLM, vLLM 등 같은 프레임워크를 쓰는 수많은 서비스에 영향을 미쳐 업계에서 크게 화제가 됐던 취약점입니다.

지금 우리 서비스에 실제로 통하나요?

확실하지 않습니다(서버 직접 접근 없이는 확정 불가). 이 앱의 관리자 로그인은 Host 헤더가 아니라 비밀번호+세션 쿠키 방식이라 당장 눈에 띄는 우회 경로는 없어 보입니다. 하지만 이건 프레임워크 자체의 요청 처리 단계에서 벌어지는 문제라, 코드만 봐서는 "우리는 안전하다"고 100% 단정할 수 없습니다.

지금 바로 할 것

서버에서 실제 설치된 버전을 확인하세요:

```
cd ~/sumeungil/deploy
```

docker compose exec backend pip show starlette

버전이 1.0.1 미만이면 즉시 업그레이드가 필요합니다. FastAPI 0.115.6이 구버전 Starlette로 상한을 걸어뒀을 수 있어, 경우에 따라 FastAPI 자체를 최신 버전으로 올려야 할 수도 있습니다(호환성 확인 필요). 백엔드는 이미지 빌드형이라 `docker compose build backend && docker compose up -d backend`로 재빌드까지 해야 반영됩니다.

이미 전 세계에 공개된 CVE라 익스플로잇 난이도가 낮습니다. 다른 어떤 항목보다 먼저 확인하시길 권합니다.

🔴 기존 발견의 근본원인 확인 (소스코드로 재검증)

1. 코스 공유 API 무검증 저장 — 근본 원인 확정

`backend/app/schemas/community.py`에서 실제 코드를 확인했습니다:

```
class ShareCreateRequest(BaseModel):
    ...
    course: dict[str, Any]  # 주석: "서버는 내용을 해석하지 않는다"
```

코드 작성자 스스로 "서버는 이 내용을 검증하지 않고 그대로 저장한다"고 주석에 명시해뒀습니다. 크기(32KB)·중첩 깊이(16)만 검사할 뿐, 내용물은 전혀 검증하지 않습니다. 의도적인 **MVP/**데모 단계의 설계 선택이지 실수가 아닙니다 — 그래서 더더욱 상용 전환 전에는 반드시 고쳐야 합니다. (권고사항은 기존과 동일: 스팟 ID만 받고 나머지는 서버가 자체 데이터로 재조회)

2. 보안 헤더 부재 — 원인 확정 + 팀이 이미 알고 있던 문제

`deploy/nginx.conf`를 확인한 결과 `X-Frame-Options`, CSP, HSTS, `X-Content-Type-Options` 관련 설정이 전혀 없습니다. 흥미롭게도 저장소의 오늘자 인수인계 문서를 보니, 팀이 이미 이 문제를 **"Mn-7: 보안 헤더 + HSTS 단계 적용"**으로 백로그에 등록해뒀더군요. HSTS는 "인증서 자동 갱신이 한 번 성공하는 걸 확인한 뒤에 켜겠다"는 합리적인 이유로 미루고 있었습니다(HSTS는 브라우저에 강하게 캐시되기 때문에, 갱신이 실패하면 사이트 전체가 완전히 막힐 위험이 있음).

다만 **`X-Frame-Options`/CSP**는 **HSTS**와 그 위험이 다릅니다 — 브라우저에 영구 캐시되지 않고 되돌리기 쉬우므로, 굳이 갱신 확인까지 기다리지 않고 지금 바로 추가해도 안전합니다.

3. Rate Limit 우회 — 정정(심각도 하향)

`backend/app/middleware/rate_limit.py`와 `config.py`를 확인한 결과, 코스 공유 API는 사실 **2**중 방어로 설계돼 있었습니다:

- ① 기기 ID 기준 5회/분 (블랙박스에서 우회 확인한 것)
- ② **IP** 기준 **20**회/분 (미들웨어 레벨, 코드 주석에 "기기 ID는 클라이언트가 무한히 바꿀 수 있어서, IP 기준이 그 우회를 막는 바깥 방어선"이라고 명시됨)

즉 정확히 저희가 발견한 그 우회 시나리오를 막기 위해 이미 만들어둔 장치였습니다. 블랙박스 점검에서는 요청을 8~9건만 보내서 IP당 20회 한도에 도달하지 못해 "사실상 무제한"처럼 보였을 뿐, 실제로는 상한이 있습니다. 다만 20회/분은 개인 한도(5회)의 4배라 여전히 느슨하고, IP 자체를 바꾸면(프록시·VPN) 이 방어도 우회는 가능하므로 — "무제한"은 아니지만 근본 해결(코스 데이터 검증 항목)은 여전히 유효한 권고입니다.

✅ 소스코드로 확인된 안전한 설계 (참고용)

- 관리자 인증 구현이 상당히 견고합니다 — 메모리 하드 KDF(scrypt) 비밀번호 해싱, 자체 서명 세션 토큰, 타이밍 공격 방지 상수시간 비교, 하드코딩된 기본 비밀번호·백도어 전무, 관리자 기능을 설정하지 않으면 관련 경로 자체가 서버에 등록조차 되지 않아 정말로 "존재하지 않는" 상태가 됩니다.
- IP 위조 방지: nginx가 `X-Forwarded-For` 헤더를 클라이언트가 보낸 값이 아니라 실제 접속 IP로 강제로 덮어씁니다 — 레이트리밋을 헤더 위조로 우회하는 걸 막는 좋은 설계입니다.
- 저장소 전체에서 하드코딩된 API 키·비밀번호 패턴을 검색했으나 발견되지 않았습니다. `.env` 파일은 `.gitignore`로 잘 제외돼 있고, 템플릿(`.env.example`)에도 실제 값이 없습니다.
- 공유 코스에 크기·개수·보존기간 등 3~4중 상한이 걸려 있어, 위의 rate limit 우회가 있어도 디스크를 가득 채우는 형태의 서비스 마비로는 이어지기 어렵게 설계돼 있습니다.

📦 프론트엔드 의존성 (package.json)

패키지	버전	상태
next	14.2.35	알려진 주요 CVE(CVE-2025-55173,

패키지	버전	상태
		CVE-2024-51479, CVE-2026-29057) 전부 패치된 버전 이후. 다만 **Next.js 14.x**는 이제 **EOL(**지원 종료**)** — 이후 새로 발견되는 취약점은 패치를 보장받지 못함. 공모전 이후 Next 15/16으로 업그레이드 계획 권장
react / react-dom	18.3.1	특이 이슈 없음
typescript 등 devDependencies	-	빌드 시에만 쓰이는 도구라 런타임 위험 낮음

📦 백엔드 의존성 (requirements.txt)

패키지	버전	상태
fastapi	0.115.6	위 Starlette 이슈 참고
starlette (전이 의존성, 미고정)	불명	🔴 위 최우선 항목 참고
httpx	0.28.1	특이 이슈 없음
pydantic	2.10.4	특이 이슈 없음
uvicorn[standard]	0.34.0	특이 이슈 없음

참고: 백엔드는 lock 파일(`pip freeze` 결과 고정본)이 없어 실제 배포된 정확한 버전을 저장소만으로는 확정할 수 없습니다. `requirements-lock.txt`나 `pip-tools`/`uv` 도입을 검토하면, 다음에 이런 취약점이 나왔을 때 "우리가 정확히 어떤 버전을 쓰고 있는지" 바로 답할 수 있어 대응이 빨라집니다.

참고 — 팀 자체 보안 백로그 중 미해결로 보이는 항목

이번 점검과는 별개로, 저장소의 오늘자 인수인계 문서에 팀이 스스로 남긴 미해결 항목들이 있어 놓치지 않도록 다시 공유합니다(서버 직접 접근이 없어 저희가 직접 검증하지는 못했습니다):

- **Tmap API** 콘솔의 **IP** 허용목록에 예전에 반납한 서버 **IP**가 아직 남아있을 수 있음 — 반납된 IP는 AWS 풀로 돌아가 다른 사용자가 받을 수 있어, 방치하면 그 사람이 우리 API 키의 무료 쿼터를 대신 써버릴 수 있습니다. 문서에 "대표 확인 필요"로 명시돼 있었습니다.
- 서버에 `.env.bak-*` 형태로 예전 비밀번호 검증 파일 조각이 남아있을 수 있음 — 정리 예정으로 기록돼 있었습니다.
- 관리자 세션을 강제로 끊는(revoke) 서버 측 기능이 없어, 세션이 탈취되면 최대 4시간은 막을 방법이 없습니다.

종합 정리 — 지금 뭘 먼저 하면 되나요?

1. **[**지금 즉시**]** 서버에서 Starlette 버전 확인 → 취약하면 즉시 업그레이드
2. **[**지금 즉시**]** 보안 헤더 추가 (X-Frame-Options/CSP는 오늘 바로 가능, HSTS만 인증서 갱신 확인 후)
3. **[**상용 전 필수**]** 코스 공유 API 서버 측 검증 추가
4. **[**여유 될 때**]** 백엔드 의존성 lock 파일 도입, Next.js 14 → 15/16 업그레이드 계획, Tmap IP 허용목록 정리

본 문서는 *2026-08-10* 진행된 *5*차 세션*(*소스코드 *SAST +* 의존성 취약점 점검*)* 결과입니다*.* *1~4*차 블랙박스 점검 결과는 별도 문서를 참고하세요*.*